

Contents

Scruple Guardian — Distributed Hardware-Attested Pipeline Integrity	1
1. Executive summary	1
2. Problem statement — the residual trust gap at C2PA L2	2
3. Threat model	2
4. Architecture	3
4.1 Component overview	3
4.2 Guardian node	4
4.3 Guardian consortium	5
4.4 On-chain aggregation	5
4.5 Observation protocol	6
4.6 Verification path	7
5. Security properties	7
6. Trade-offs and limitations	8
6.1 Not a per-sign gate	8
6.2 Recursive attestation problem	8
6.3 Capital cost	8
6.4 Blockchain dependency	8
6.5 Cold-start problem	8
6.6 Operational complexity	8
6.7 Standards timing	9
7. Novel aspects (patent-relevant)	9
8. Cost model summary	9
9. Roadmap and phasing	10
10. Open questions	10
11. References	11

Scruple Guardian — Distributed Hardware-Attested Pipeline Integrity

Version: v0.1 **Author:** Shaun Hargadine, Docent LLC **Date:** 2026-08-05 **Classification:** Internal architecture design — pre-patent draft (do NOT publish externally before provisional filing) **Related:** SCRUPLE_C2PA_L2_GPSA_v3, Jailbird TME architecture, Scruple Standard v1

1. Executive summary

Scruple Guardian is a **continuous, geographically-distributed, hardware-attested integrity monitor** for the entire Scruple C2PA signing pipeline. Unlike the C2PA Level 2 Signer, which attests its own integrity from inside the pipeline, Guardian sits **outside every trust boundary the Signer depends on** — running on Docent’s TME-on-FPGA substrate, deployed across N geographically-separated nodes, reaching Byzantine-fault-tolerant consensus on pipeline observations, and minting the consensus record autonomously to a public blockchain via smart contract.

The design targets a threat model that C2PA Level 2 (as currently defined) does not address: **coordinated insider compromise of the cloud infrastructure hosting the Signer**. It also targets what the C2PA program has described as the direction of Level 3 and above: **independent third-party attestation with continuous evidence**.

Guardian augments C2PA Level 2 conformance; it does not replace it. Scruple ships L2 with or without Guardian. Guardian is a separate product tier (“Scruple L2 with Guardian”) for customers whose use case demands proof-beyond-vendor-attestation.

2. Problem statement — the residual trust gap at C2PA L2

The C2PA Level 2 Generator Product Security Requirements are defensible security engineering: hardware-attested key custody, TEE-hosted signing, patch recency, cert enrollment discipline. Scruple’s GPSA v3 satisfies all of them.

But every L2 architecture — Scruple included, and every peer on the current Conforming Products List — has the same residual trust:

- **The cloud operator is trusted.** OCI, AWS, Azure, GCP employees with sufficient access can, in principle, alter the CVM image, swap the signing binary, downgrade a package, exfiltrate the HSM handle, or replace the code that runs inside the TEE. The C2PA spec addresses this partially (via patch-recency, image-hash attestation, etc.) but the attestation is **produced by the same trust boundary that would be compromised**. A compromised OCI operator can produce a valid-looking SEV-SNP report of a compromised image.
- **The Signer operator is trusted.** Scruple employees with sufficient access have the same category of power over the pipeline. Same self-attestation limitation applies.
- **The attestation cadence is coarse.** L2 patch recency is a 90-day window; SEV-SNP reports are generated at CVM boot or per-request but consumed by the same trust boundary that could have compromised them.
- **The evidence is not third-party-verifiable at the time of signing.** A verifier receiving a signed manifest today can validate the cert chain and (with our GPSA v3) confirm the OS patch date at signing time. That’s an assertion made by the Signer about itself, at signing time. There is no independent evidence from that moment.

The Guardian addresses each of these by: - Sitting **outside the cloud operator’s trust boundary** (customer-premises or independent-consortium hardware) - Sitting **outside Scruple’s trust boundary** (operated in whole or in part by independent parties) - Producing observations **continuously** (hourly rather than 90-day) - Anchoring observations to **public blockchain infrastructure** independent of both the cloud operator and Scruple

3. Threat model

Guardian is designed against a **coordinated insider adversary** with the following powers:

Adversary capability	Guardian response
Root access to a Signer CVM	Guardian's observation captures image hash + patch date + process manifest; divergence from the expected value trips consensus within one attestation cycle
Access to OCI console / IAM to swap CVM images	Same as above; Guardian sees the new image hash
Ability to compromise Scruple's HSM slot (steal key handle)	Guardian observes key attestation state per cycle; unauthorized key export attestation trips consensus
Ability to alter Scruple's Application-tier code	Guardian observes Application tier's binary hash + git commit reference; drift detected
Ability to swap the Signer's certificate	Guardian observes the cert chain served by Signer; cert change trips consensus
Ability to alter Scruple's git history to hide the swap	Guardian observations are minted to public blockchain — post-hoc rewrites cannot alter the historical record
Ability to compromise a single Guardian node (physical or supply-chain)	Byzantine-fault-tolerant consensus: N-of-M must agree; single-node compromise cannot mint
Ability to compromise multiple Guardian nodes (state-actor scale)	Consortium diversity (jurisdiction, network, hardware vendor, operator) makes this genuinely expensive
Ability to bribe/coerce Scruple to alter Guardian observations post-hoc	Impossible — observations are signed by Guardian FPGAs with keys Scruple does not have; on-chain records are immutable

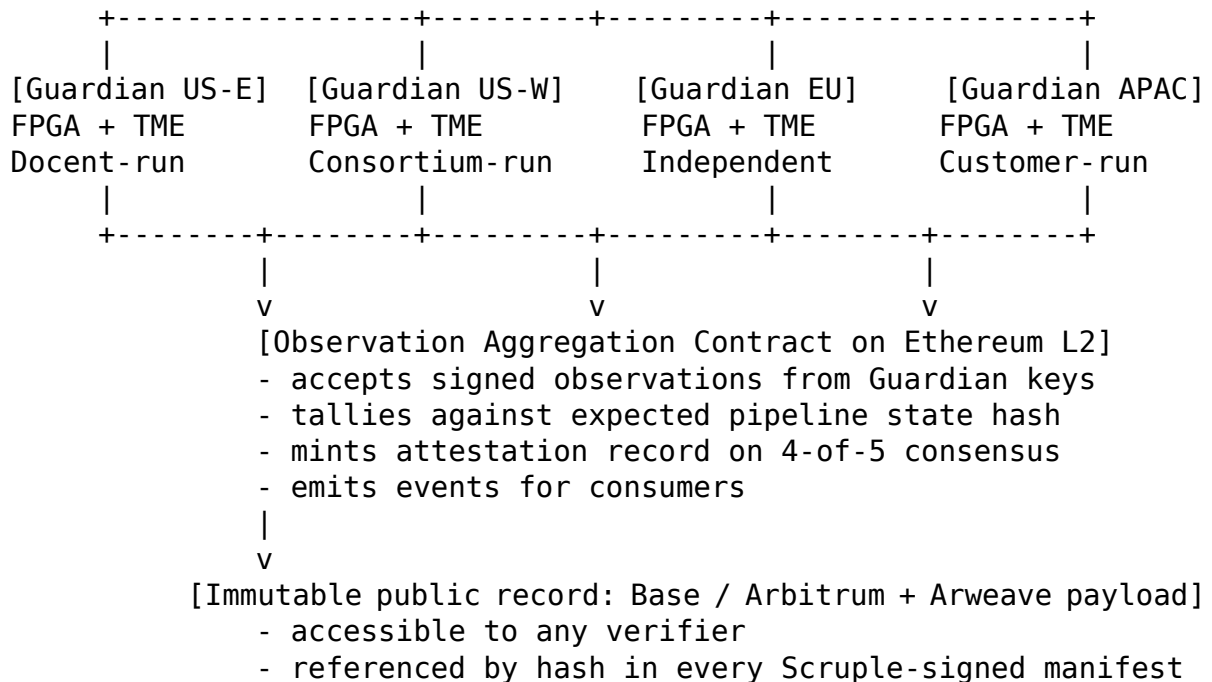
Explicitly out of scope: - Compromise of the Signer's underlying cryptographic primitives (ES256, SHA-256). If ECDSA breaks, everything is affected — not a Guardian concern. - Physical seizure of a Guardian FPGA followed by successful bitstream extraction. Xilinx / Altera bitstream encryption + anti-tamper zeroization make this expensive and detectable, but not impossible against a state-actor with weeks of physical access. Consortium diversity is the answer. - Compromise of the underlying blockchain (Ethereum L2 or equivalent). If Ethereum finalizes a rewrite, our anchors would be affected. Multi-chain anchoring (see §6.4) is the answer.

4. Architecture

4.1 Component overview

PUBLIC INTERNET

|



OBSERVED PIPELINE
(unmodified – Guardian is out-of-band)

```

Client ---> Application Tier CVM ---> Signer CVM ---
> Witness Server CVM
    (Next.js)                      (HSM + c2pa)    (audit + Merkle)
  
```

4.2 Guardian node

Each Guardian node is a single FPGA-based appliance:

- **Hardware substrate:** Xilinx Kintex UltraScale+ or Intel Agilex FPGA (target class: \$3-8K per board). Same silicon family as Jailbird TME appliances.
- **Bitstream:** Docent-authored, encrypted with AES-256, authenticated with SHA-3 HMAC per Xilinx UltraScale+ security features. Bitstream hash published; verifiable by third-party audit at build time.
- **Root key:** Non-extractable per-appliance ECDSA P-384 key generated inside the FPGA at initial provisioning ceremony. Bound to the FPGA's Device DNA (unique per silicon). Public half published as part of the consortium roster.
- **Attestation surface:** Guardian responds to attestation-request queries with (a) its own bitstream hash + Device DNA proof, (b) its current time reference (multi-source NTP + on-chain block timestamp cross-check), (c) its most recent observation of the target pipeline.
- **Observation engine:** The Guardian's core function. Periodically (default: hourly) queries the target Scruple pipeline via a documented observation protocol (§4.5), signs the observation with its FPGA-attested key, submits to the on-chain aggregation contract.

- **Anti-tamper:** Board-level tamper sensors (accelerometer, temperature, light, voltage) trigger irreversible bitstream zeroization on physical intrusion.
- **Operational surface:** No SSH, no shell, no OS. Firmware updates require a signed bitstream from a Docent-controlled multi-party ceremony key (M-of-N of the Docent leadership team). Update installs into the alternate bitstream slot and requires cold power cycle to activate; the currently-running slot is never mutated in place.

4.3 Guardian consortium

A Guardian consortium is a set of N Guardian nodes deployed across dimensions that maximize resistance to correlated compromise:

- **Geographic diversity:** Different power grids, different physical regions
- **Jurisdictional diversity:** Different national legal reach (US, EU, Ireland, Singapore, Japan)
- **Network diversity:** Different upstream ASNs / carriers
- **Hardware vendor diversity:** At least two of Xilinx (AMD), Altera (Intel), Lattice
- **Operator diversity:** Some Docent-run, some independent-consortium-run, some customer-run

Byzantine fault tolerance requires $N \geq 3f + 1$ to tolerate f compromised nodes. Recommended consortium sizes:

Consortium size	Tolerates faulty	Target market
4 nodes	1	Standard commercial “Guardian” tier
7 nodes	2	Enterprise / journalism / legal-evidence tier
10+ nodes	3+	High-assurance / regulated (defense, finance)

Consortium membership is a smart-contract-registered set. Adding a new Guardian requires an on-chain vote among existing consortium operators. Removing a compromised Guardian requires the same. The consortium’s own governance is on-chain and auditable.

4.4 On-chain aggregation

The Aggregation Contract (target platform: Ethereum L2 — Base or Arbitrum — with Solana as an alternative option) has three public functions:

- `submitObservation(observation, signature)` — accepts a signed observation from a registered Guardian. Verifies the signature against the on-chain Guardian roster.
- `mintAttestation()` — invocable by anyone after M-of-N observations agree on a canonical pipeline state hash within a defined time window; emits an `AttestationMinted` event and writes the record to the contract’s storage.
- `disagreement()` — invocable if observations diverge; emits a `PipelineDivergence` event so consumers can react (e.g., halt signing, alert operators).

Storage strategy: - **On-chain**: hash of observation payload + signer identifier + timestamp + consensus decision. Cheap enough to be economical. - **Off-chain (Arweave)**: full observation payloads. Referenced from the on-chain record by Arweave transaction ID. Permanent, content-addressable, cheap at Arweave's economics.

Anchor economics (rough order-of-magnitude, Base L2, mid-2026 gas): - Per observation submission: ~\$0.02-0.10 - Per mint (once threshold reached): ~\$0.05-0.20 - Hourly cadence x 24 hours x 30 days x M signers = ~\$100-500/month per consortium

4.5 Observation protocol

Each Guardian, on each attestation cycle, collects and signs the following observation record about the target Scruple pipeline:

```
{
  "guardian_id": "gd_abc123...",
  "observation_id": "obs_2026-08-05T14:00:00Z_gd_abc123",
  "target_pipeline_id": "scruple-prod",
  "observed_at": "2026-08-05T14:00:00Z",
  "components": {
    "application_tier": {
      "endpoint": "https://scruple.ai/api",
      "tls_cert_fingerprint": "sha256:...",
      "http_health_check": "ok",
      "attested_binary_hash": "sha256:...",
      "attested_git_commit": "abc1234"
    },
    "signer_cvm": {
      "sev_snp_report_hash": "sha256:...",
      "hsm_key_public_fingerprint": "sha256:...",
      "os_security_patch_date": "2026-08-04T02:00:00Z",
      "cvm_image_id": "ocidl.image.ocl.iad...",
      "cvm_born_at": "2026-08-01T00:00:00Z"
    },
    "witness_server": {
      "leaf_schema_version": "v2.4",
      "checkpoint_key_fingerprint": "sha256:...",
      "os_security_patch_date": "2026-08-04T02:00:00Z"
    }
  },
  "pipeline_state_hash": "sha256:...",
  "guardian_signature": "..."
}
```

The `pipeline_state_hash` is the canonical single-value summary of the observation — its sole purpose is to enable N-of-M consensus by simple equality comparison. Consensus is defined as: the same `pipeline_state_hash` appears in at least M Guardian observations submitted within a defined time window (e.g., 15 minutes).

Guardians obtain each observation field through documented, auditable means:

- `tls_cert_fingerprint`: standard TLS fingerprint from a fresh HTTPS handshake - `sev_snp_report_hash`: query the Signer CVM's public attestation endpoint (exposed under mTLS from Guardian to a dedicated attestation port) - `hsm_key_public_fingerprint`: from the same attestation endpoint (HSM SPKI hash bound into `report_data`) - `os_security_patch_date`: from the Signer's public patch-recency endpoint (a wrapper around `patch_recency_verdict()` from GPSA v3 §C.2.3.0) - `attested_binary_hash / attested_git_commit`: from a Scruple-published "build manifest" signed at CI time; Guardian fetches the manifest and cross-checks against a running-binary-hash query

Scruple must expose new dedicated **read-only attestation endpoints** for Guardian to query, distinct from the signing endpoints. These endpoints are themselves attested; a compromised Application tier cannot substitute observations.

4.6 Verification path

Any consumer of a Scruple-signed manifest can independently verify Guardian-attested pipeline integrity as follows:

1. Read the signed manifest; note the `ai.scruple.signer-runtime.v1` assertion which references a Guardian attestation hash + block number (added in GPSA v4).
2. Query the on-chain Aggregation Contract for that attestation record.
3. Retrieve the Arweave payload referenced by the on-chain record.
4. Verify each Guardian signature against the on-chain roster.
5. Confirm the consensus threshold was met.
6. Compare the attested `pipeline_state_hash` against the Scruple-published expected state at that time.

No Scruple involvement in step 2-6. No Scruple key can rewrite step 2-6. The Guardian evidence stands independent of Scruple's continued operation.

5. Security properties

- **Insider-resistance.** Neither Scruple ops nor OCI ops can compromise a Guardian consortium acting from within Scruple's or OCI's boundary. Compromise requires either physical attack on N-f Guardian appliances or supply-chain compromise of N-f FPGA vendors — both state-actor scale.
- **Continuous evidence.** Hourly attestation vs 90-day per-sign is a ~2000x improvement in temporal resolution of the integrity signal.
- **Public verifiability.** Every attestation is minted on-chain and its payload permanently anchored. Any third party — customer, auditor, journalist, court — can independently verify without Scruple cooperation.
- **Post-hoc immutability.** A Guardian attestation minted today at hour T cannot be altered at hour T+N by any party, including Scruple.
- **Tamper-evident.** Any drift in the observed pipeline state emits a public `PipelineDivergence` event. Consumers can subscribe.
- **Fail-visible.** If Guardian nodes go offline, the absence of fresh attestations is itself a signal — consumers can define policies (e.g., "reject any manifest not

covered by an attestation within the last 6 hours”).

6. Trade-offs and limitations

6.1 Not a per-sign gate

Guardian’s finest cadence is limited by consensus latency (seconds to minutes) and blockchain finality (~2-15 seconds on L2). This is fine for detecting divergence within an hour. It is NOT a per-sign gate. Every C2PA sign still uses the L2 gate mechanisms; Guardian is the meta-evidence that those gates ran on an uncompromised pipeline.

6.2 Recursive attestation problem

How does a consumer verify the Guardian FPGA bitstream itself hasn’t been tampered? The design’s answer: (a) bitstream hash is published as part of consortium onboarding, (b) at least one Guardian’s bitstream must be independently audited by a third party at build time, (c) consortium diversity means at least one Guardian’s bitstream is verifiable by parties Scruple cannot influence. This is a “verify N of M” claim, not “verify all M.”

6.3 Capital cost

FPGA hardware (\$3-8K per board) x 4-10 nodes + geographic co-lo + operational overhead makes Guardian meaningfully more expensive per unit-of-attestation than the base L2 signer. This is not a \$99/month feature — it is an enterprise or shared-consortium tier.

6.4 Blockchain dependency

The design depends on a specific L2 chain remaining operational and honest. Multi-chain anchoring (attestations minted to two independent chains) is straightforward extension but doubles anchor cost.

6.5 Cold-start problem

The first Guardian consortium must be provisioned before any customer can use it. Do-cent bears the initial infrastructure cost. Recovery: charge a “Guardian tier” premium recovers infra over ~50-200 customer-months.

6.6 Operational complexity

Managing 4-10 geographically distributed FPGA appliances with hardware maintenance, firmware update ceremonies, on-chain governance votes, blockchain fee monitoring is a nontrivial operational surface. Not appropriate as a solo-founder overnight side project; requires a dedicated ops team or partnership with an FPGA-as-a-service provider (e.g., AWS F1 instances at commodity scale, though AWS F1 is not appropriate for an attestation authority since it re-introduces the AWS trust boundary

— but similar hardware-as-a-service providers with independent operational trust could work).

6.7 Standards timing

C2PA Level 3 has not opened for filings. Guardian is a bet on where L3+ requirements land. If C2PA takes a different direction (e.g., embraces cloud-vendor-native attestation only), Guardian’s positioning shifts from “prototype of L3” to “beyond-C2PA independent attestation.” Either way it holds market value; the specific standards-mapping story adapts.

7. Novel aspects (patent-relevant)

The following combinations are, to our knowledge as of 2026-08-05, novel and not documented in any public prior art (initial claim — full prior-art search pending):

1. **FPGA-hosted attestation of a distinct signing pipeline** — as opposed to FPGA-hosted signing itself. The FPGA’s role here is observer, not signer. This inverts the usual FPGA-security discussion.
2. **Byzantine-fault-tolerant consensus among N geographically-distributed hardware attestors** for the purpose of continuously attesting a signing infrastructure’s integrity to a public ledger.
3. **Autonomous smart-contract aggregation** of hardware-attested pipeline observations, with on-chain governance of consortium membership and attestation threshold.
4. **Pipeline observation via ephemeral attested queries** to a signing infrastructure that itself uses TEE attestation — with the two attestation substrates (FPGA at Guardian, TEE at Signer) being architecturally independent.
5. **Binding the Guardian attestation hash into the signed manifest itself** (§4.6) as a first-class field, providing per-manifest reference to independent pipeline evidence.
6. **Consortium diversity dimensions as a security property** — jurisdictional, geographic, network, hardware vendor, operator — as the explicit design axis for compromise resistance in the attestation authority itself.

Prior art we control (not novel but load-bearing): - Jailbird TME architecture (see `project_tme_architecture.md`) — the FPGA substrate this design reuses - Scruple C2PA L2 GPSA v3 (see referenced doc) — the pipeline this design attests

8. Cost model summary

Rough 3-year TCO for a 5-Guardian consortium (order-of-magnitude, mid-2026 assumptions):

Line item	Year 1	Year 2	Year 3
FPGA hardware capex (5 x \$6K)	\$30,000	—	\$15,000 (refresh 2-3 boards)
Co-lo hosting (5 sites x \$200/mo)	\$12,000	\$12,000	\$12,000
On-chain anchor gas (~\$300/mo)	\$3,600	\$3,600	\$3,600

Line item	Year 1	Year 2	Year 3
Bitstream engineering (initial + updates)	\$50,000	\$20,000	\$20,000
Consortium governance ops	\$10,000	\$15,000	\$20,000
Total	~\$105K	~\$50K	~\$70K
3-year total			~\$225K

Pricing model (candidates, not decided): - **Per-attested-signer add-on:** \$500-2,000/month per Scruple deployment attested - **Shared consortium tier:** \$200-500/month per customer riding shared Guardian infrastructure - **Dedicated consortium tier:** \$10-25K/quarter for customer-run Guardians in customer-chosen jurisdictions

Break-even on \$225K over 36 months requires ~\$6.5K/month in Guardian revenue. Achievable with 12-30 shared-tier customers or 2-5 dedicated-tier customers.

9. Roadmap and phasing

Phase 0 — provisional patent filing (before ANY external disclosure) - Prior-art search - Provisional application draft covering §7 novel aspects - Filing

Phase 1 — reference implementation (post-filing) - Single Guardian FPGA bitstream (reuse Jailbird TME substrate) - Reference observation protocol implementation - Reference Ethereum L2 aggregation contract (initially on testnet) - Local dev harness (docker-compose stand-in for the observed pipeline)

Phase 2 — pilot consortium - 3-node consortium: 2 Docent-run, 1 independent-partner-run - Attesting Scruple production Signer CVM - Anchoring to Base or Arbitrum testnet - Six-month observation baseline

Phase 3 — production launch - Full 5-node consortium - Mainnet anchoring - First commercial “Scruple L2 + Guardian” customer - GPSA v4 appendix documenting Guardian augmentation

Phase 4 — standards conversation - Publish Guardian architecture (post-filing) as academic/industry white paper - Engage C2PA Program on how Guardian maps to L3+ criteria - Position for L3 filing when Program opens L3 review

10. Open questions

1. **Which L2 blockchain?** Base vs Arbitrum vs Solana. Base is emerging as the enterprise choice; Arbitrum has more DeFi maturity; Solana is cheaper but less enterprise-adopted. Decision needed before Phase 1 contract implementation.
2. **How is a customer’s expected pipeline_state_hash published?** Docent-signed manifest per Scruple release? On-chain registry? Third-party notary?
3. **Recursive attestation depth.** How many layers of “attest the attestor” are practical? At some point trust must anchor to physical audit — where?
4. **Consortium governance model.** Simple M-of-N voting, or weighted based on operator reputation / uptime / jurisdiction? On-chain DAO or off-chain multi-sig?

5. **Failure-mode UX.** When Guardian detects PipelineDivergence, what happens? Does Scruple automatically halt signing? Log-and-continue? Customer-configurable policy?
6. **Interaction with Scruple witness server L2 parity.** The witness server needs its own L2-parity hardening (per session discussion 2026-08-05). Guardian attests the witness server as one of the pipeline components. But the witness server itself would ALSO benefit from a Guardian consortium if operated at scale. Meta-Guardian? Or does the same Guardian cover both?

11. References

- C2PA Generator Product Security Requirements v0.1 (Program spec)
- Scruple GPSA v3 (this repo, docs/c2pa-conformance-evidence/2026-07-30/security-architecture/01-GPSA.md)
- Jailbird TME architecture (Docent internal, memory project_tme_architecture.md)
- C2PA L2 peer landscape survey (2026-08-05, this repo docs/c2pa-conformance-evidence/2026-07-30/c2pa-l2-peer-landscape.md)
- Xilinx UltraScale+ Security Features Reference (public docs)
- Trust Over IP recap of Scott Perry / C2PA Conformance Program EGWG session, 2025-05-15
- “Signing Right Away: Continuous Attestation of TEE-Based Signing,” arxiv 2510.09656 (referenced approach; distinct from Guardian)